

Anti-Phishing Training (Still) Does Not Work: A Reproduction of Phishing Training Inefficacy Grounded in the NIST Phish Scale

Andrew T. Rozema

Purdue University
West Lafayette, Indiana, USA
Grand Rapids Community College
Grand Rapids, Michigan, USA
arozema@purdue.edu

James C. Davis

Purdue University
Electrical & Computer Engineering
West Lafayette, Indiana, USA
davisjam@purdue.edu

Abstract

Social engineering attacks delivered via email, commonly known as phishing, represent a persistent cybersecurity threat leading to significant organizational incidents and data breaches. Although many organizations train employees on phishing, often mandated by compliance requirements, the real-world effectiveness of this training remains debated. Past work has demonstrated the ineffectiveness of training, but reproduction across different organizations, training approaches, and with a standardized threat assessment will help the generalizability of this phenomenon.

To contribute to evidence-based cybersecurity policy, we conducted a large-scale reproduction study ($N=12,511$) at a US-based financial technology firm. Our design refined prior work by comparing training modalities in operational environments, applying NIST's standardized phishing difficulty measurement, and introducing novel organizational-level temporal resilience metrics.

Echoing prior work, training interventions showed no significant main effects on click rates ($p=0.450$) nor reporting rates ($p=0.417$), with negligible effect sizes. However, we found that the NIST Phish Scale predicted user behavior, with click rates increasing from 7.0% (easy lures) to 15.0% (hard lures). Our organizational-level resilience result was mixed: 36-55% of campaigns achieved "inoculation" patterns where reports preceded clicks, but training did not significantly improve organizational-level temporal protection. Our results confirm the ineffectiveness of current phishing training approaches and offer a refined study design for future work.

CCS Concepts

• Social and professional topics → Phishing.

Keywords

Phishing, Training, Cybersecurity Defenses, Empirical Study

ACM Reference Format:

Andrew T. Rozema and James C. Davis. 2026. Anti-Phishing Training (Still) Does Not Work: A Reproduction of Phishing Training Inefficacy Grounded in the NIST Phish Scale. In *Proceedings of the ACM Web Conference 2026 (WWW '26)*, April 13–17, 2026, Dubai, United Arab Emirates. ACM, New York, NY, USA, 12 pages. <https://doi.org/10.1145/3774904.3792467>



This work is licensed under a Creative Commons Attribution 4.0 International License. WWW '26, Dubai, United Arab Emirates

© 2026 Copyright held by the owner/author(s).
ACM ISBN 979-8-4007-2307-0/2026/04
<https://doi.org/10.1145/3774904.3792467>

1 Introduction

Phishing is a primary attack vector [31] and regularly harms organizations through operational incidents, data breaches, and financial losses [3]. For, in 2022–2023 campaigns attributed to the *Scattered Spider* cluster compromised 9,931 accounts in over 130 organizations [20, 32]. This campaign cost MGM Resorts alone an estimated \$100 million [53]. To prevent this class of attacks, organizations employ technical controls (e.g., spam filters, attachment analyzers) complemented by cybersecurity awareness training [36, 48].

Despite organizational and regulatory emphasis on anti-phishing training, its effectiveness is questioned by mounting empirical evidence [36, 41, 42] and employee sentiment [52]. Most pertinently, Lain *et al.* found that phishing training did not improve security outcomes across 19,000+ employees over years [41, 42]. These findings align with theoretical work by Volkamer *et al.*, who show fundamental limitations in human processing of security indicators [66].

These prior studies support the general contention that phishing training is ineffective. In this work we refine our understanding by addressing two specific knowledge gaps. First, existing studies lack standardized measures of phishing difficulty, so we do not know whether training effectiveness varies by attack sophistication. Second, most studies examine single training modalities rather than comparing different approaches systematically, so we do not know if some training designs are more effective than others.

To address these limitations, we conducted a large-scale reproduction study ($N=12,511$) at a US-based financial technology firm.¹ Our study design has three distinctive elements: (1) *mandatory pre-phishing training* using two distinct training modalities (lecture-based vs. interactive); (2) *systematic difficulty assessment* using the NIST Phish Scale [6, 61]; and (3) a *novel organizational temporal resilience measurement* through our Organizational Inoculation Index. Our design evaluates training effectiveness across standardized difficulty levels, and brings new insights into organizational cybersecurity resilience patterns to complement individual ones.

We confirm the ineffectiveness of anti-phishing training across multiple dimensions, but add nuance to prior results. Consistent with prior work, neither training modality produced statistically significant improvements in phish click reduction ($p=0.450$) nor phish reporting behavior ($p=0.417$), with negligible effect sizes indicating minimal practical value for individuals. However, the NIST Phish Scale successfully predicted user behavior ($F(2, 12086)=41.415$, $p < 0.001$, $\eta^2=0.007$), providing the first large-scale validation of this

¹Our reproduction effort differs from **replication**, which would repeat identical procedures. Instead, we focus on testing the **generalizability** of the phenomenon of training ineffectiveness, varying organizational context and training approach.

standardized difficulty measure.² Beyond that, our Organizational Inoculation Index revealed substantial organizational resilience that operates independently of individual training effectiveness. Across all experimental conditions, 36%–55% of template-group combinations demonstrated “inoculation” patterns where threat reports from one employee preceded threat interaction by others.

In summary, we contribute:

- (1) *Reproduction of Training Ineffectiveness.* We reproduce the core finding of phishing training ineffectiveness.
- (2) *First Large-Scale Validation of NIST Phish Scale.* We show the NIST Phish Scale predicts phishing lure difficulty.
- (3) *Introduction of the Organizational Inoculation Index.* We introduce a novel metric for organizational temporal security. We find substantial organizational resilience (36-55% inoculation rates), independent of individual training effectiveness.

Significance: Cybersecurity practice and policy must be evidence-based. For *regulators*, our work adds more evidence that phishing training is ineffective. For *organizations*, our results suggest realistic (low) expectations about training outcomes and highlight the importance of technical controls to assist humans. We also found that collective security behaviors may create measurable protective effects, emphasizing the value of user/IT feedback loops for real-time threat response. For *researchers*, we validate NIST’s standardized difficulty measure and confirm the reproducibility of training ineffectiveness findings across organizational contexts.

2 Background and Related Work

We review phishing attacks and defenses (§2.1), and prior empirical studies on phishing training (§2.2).

2.1 Phishing Attacks and Defenses

Phishing attacks pose substantial risks to organizations, who erect both technical and human defenses against them.

2.1.1 Phishing Attacks. In a phishing attack, attackers send messages (*phishing lures*) to targets whom they wish to persuade to act against their own interests, and the interests of their organizations. Attackers seek results such as sensitive information, account credentials, or the ability to control the victim’s machine [3, 27]. These attacks use compromised infrastructure, browser vulnerabilities [45], look-alike domains, legitimate certificates [37] and social engineering to evade technical defenses [18, 43] and exploit human trust [2, 3]. Phishing attacks are divided into two classes [21]: mass phishing (form emails sent to many targets, often with a phishing kit [44]) and spear phishing (emails for specific targets).

2.1.2 Automated Defenses. Many technical defenses combat attackers’ behavior, such as SPF, DKIM, and DMARC to verify that mail comes unaltered from authorized infrastructure [19, 39, 40]; ARC for preserving authentication results across forwarding [4]; BIMi for verified logos [7, 9]; and secure email gateways (SEG) for content and header inspection and URL rewriting for time-of-click inspection [49]. After delivery, organizations employ continuous monitoring and feedback loops to adapt controls to evolving campaigns [48]. For an example of the dynamics [2, 3], security

operations center (SOC) analysts triage user-reported messages, promote high-confidence indicators back into blocklists, and tune SEG policies based on observed false positives/negatives.

Appendix A describes elements of the studied organization’s email controls and feedback loops.

2.1.3 Phishing Training as a Defense. Because phishing attacks compromise these technical defenses [11, 12], the human recipients play an important role in phishing defense [1, 13, 23, 25]. Training methods range from lecture-style training involving passive videos and readings [47] to simulation feedback providing immediate feedback after interaction with phishing simulations [16, 17]. Interactive training uses gamification or scenario-based learning to engage participants [8, 34], while just-in-time training alerts users in real time during risky behavior [29].

Anti-phishing trainings are often included in the cybersecurity awareness trainings ubiquitous in organizations, despite the substantial hidden costs of phishing campaigns, described by Brünken *et al.* on employee trust, organizational culture, and resource allocation. [10] Legal mandates drive this practice. For example: HIPAA requires security awareness training for healthcare organizations [64], and GDPR and PCI DSS encourage or mandate similar training [26, 51]. Industry standards reinforce these requirements [50], e.g., ISO 27001 calling for human security controls like awareness programs [28].

2.2 Empirical Studies of Phishing Training

Our review and analysis of prior work is summarized in Table 1. We contribute to the body of knowledge on phishing training by conducting another large-scale study situated in a real-world context (table columns 2-4), incorporating a complexity measure (column 5), and a comparison of multiple training approaches (column 6). Our study tests hypotheses derived from prior work (final column). The remainder of this section describes these contributions. For general surveys of knowledge about human factors in phishing training, we refer the reader to [30, 47].

Lab vs. Real-world Studies: Many early phishing training studies were conducted in controlled laboratory settings, where researchers benefit from a high degree of experimental control. Studies of this sort have provided numerous insights, including that active learning and immediate feedback can improve short-term detection rates, and have explored how individual differences affect training outcomes [47, 62]. However, as noted by Franz *et al.* [30], these controlled settings may lack ecological validity. In laboratory environments, participant samples are typically small and consist of homogeneous groups such as academics and students.

In response, a growing number of studies have begun examining phishing training in real-world organizational environments. For example, Doing *et al.* [24] analyzed phishing behaviors in bank employees, and Ho *et al.* [36] studied healthcare employees. Lain *et al.* has also conducted large-scale real-world measurements of training effectiveness [41, 42] Our study echoes some of these prior results in a different organizational context.

Controlling for Lure Complexity: These studies consistently report little effectiveness of anti-phishing training. These works have

²The effect size is (statistically) small due to low base rates of phishing engagement. Practically, click rates doubled from 7.0% to 15.0% as lure difficulty increased.

Table 1: Summary of Prior Experiments on Phishing and Training Interventions. Studies are organized by research context (Lab vs. Real-World). *Context*: “Lab” denotes research simulations, where subjects are not in their work roles. “Real-World” denotes studies where participants were employees acting in their job capacity. *Complexity measure*: Whether the study controlled for the difficulty of the phishing tasks. ✓ indicates the use of a validated, publicly available framework such as NIST Phish Scale, and ✗ indicates no control. *Hypotheses*: How these works informed the hypotheses in the present study (cf. Table 3).

Work	Context	Population	Sample size	Complexity Measure	Compared Training Approaches?	Hypotheses
[57] (2024)	Lab	University students	96	✗	✗	H3
[14] (2024)	Lab	University students	117	✓ (Phish Scale)	✗	H4
[16] (2014)	Real-world	Employees	1,359	✗	✓	H2, H4
[17] (2017)	Real-world	University students	150	✗	✓	H2, H3
[62] (2022)	Real-world	Employees	119	✗	✗	H2
[42] (2022)	Real-world	Employees	19,000+	✗	✗	H2
[35] (2023)	Real-world	Finance employees	5,000	✗	✗	H2
[41] (2024)	Real-world	Employees	4,554	✗	✓	H2, H3
[24] (2024)	Real-world	Banking employees	“Thousands”	✗	✗	H2
[36] (2025)	Real-world	Healthcare employees	19,500+	✗	✗	H2
Ours	Real-world	Fintech org.	12,511	✓ (Phish Scale)	✓	—

not, however, incorporated a standardized method for assessing the difficulty of the phishing lures they use [24, 36].

The US NIST has proposed a scale for this purpose [22, 61]. We summarize it here and give more details in Appendix B. The **NIST Phish Scale** categorizes lure difficulty along two dimensions. *Phishing Cues* represent observable errors or inconsistencies in the email that might alert users to its fraudulent nature, such as spelling mistakes, suspicious URLs, or formatting irregularities [14]. *Premise Alignment* measures the relevance of the email to the recipient’s organizational context [5]. Higher alignment messages with fewer cues are the most deceptive [12]. The premise of Phish Scale is to allow organizations to benchmark lure complexity and contextualize simulation outcomes [15]. Building on early validation work [6, 22], we contribute the first real-world measurement of the effect of lure complexity on subjects’ interaction behaviors.

Training Approaches: Franz *et al.* [30] taxonomize five categories of phishing interventions: training, awareness, education, notifications, and design interventions. Most studies have focused on training, which can be divided into lecture-style annual training and embedded training (*e.g.*, via ongoing phishing simulations from the organization’s security team). Like a few prior studies [16, 17, 41], we compare the effectiveness of two forms of phishing training.

Multiple research communities have raised critical perspectives on phishing training. Sasse and colleagues have long argued that traditional security awareness programs misframe the problem—treating employees as the weakest link rather than addressing usability issues in email and security tool design [56], in fact, Kirlappos and Sasse call for a fundamental rethink of phishing education, contending that conventional approaches rely on flawed assumptions about how people perceive and respond to security cues [38].

This study addresses those gaps by applying the NIST Phish Scale [22] to evaluate training effectiveness across varied phishing difficulty levels in an enterprise deployment with over 12,000

participants. In this study, our objectives are to: (1) operationalize the NIST framework at scale, (2) examine how difficulty influences detection and reporting across training modalities, (3) provide comparative evidence on lecture-based versus interactive approaches, and (4) offer guidance for large-scale awareness efforts under conditions of modest effectiveness [36]. This enables evidence-based decision-making on phishing defense strategies that account for both training design and message complexity.

3 Methodology

To summarize the preceding analysis: phishing training is widely practiced, though recent evidence sheds doubt on its utility. Few studies have rigorously assessed outcomes against standardized difficulty measures at sufficient scale for robust inference. We aim to reproduce, testing hypotheses derived from prior works.

3.1 Study Design

Our study design is illustrated in Figure 1. We employed a two-factor between-subjects experimental design [35]. Subjects were randomly assigned to one of three experimental conditions using our organization’s training management system. Each condition reflected the phishing training they received. Subjects were randomly selected, trained, and later received simulated phishing emails of varying complexity. We quantitatively compared subjects’ performance in handling these phishing emails between the treatments.

Factor 1: Training: The research team collaborated with a cybersecurity training vendor who produces comprehensive security awareness training materials, phishing simulation exercises designed to augment those materials, and implementation assistance for organizational deployment. This partnership enabled access to professional training content and established phishing templates.

The vendor offers two distinct training approaches for phishing. The first approach, *Treatment A*, consists of lecture-based videos

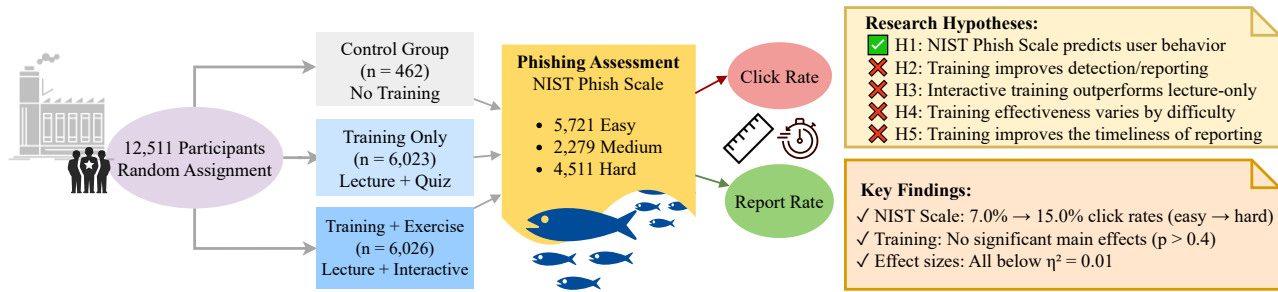


Figure 1: Illustration of our methodology. Our two-factor design randomly assigns different trainings to different subjects, and then randomly sends phishing lures of varying complexity to the subjects. We compared between-subject performance using a mix of standard and novel metrics to test our five hypotheses.

on the dangers of various social engineering attacks, including phishing recognition tactics and organizational security protocols. Comprehension is assessed through a quiz. The second approach, *Treatment B*, consists of those videos followed by a series of interactive phishing exercises that present users with samples from a library of approximately 20 phishing templates. These exercises guide users through identifying suspicious elements and security deficiencies in emails that roughly correspond to the cues assessed by the NIST Phish Scale, and reinforces appropriate response behaviors such as the “Report Phish” button in the email client [17]. Finally, we included a *Control Group* whose members received no cybersecurity training prior to the phishing simulation phase. This group yielded baseline susceptibility measurements.³

Factor 2: Phishing Lure Complexity: After training, all subjects received one simulated phishing email, of varying complexity. To establish controlled and consistent evaluation of participant responses, we systematically assessed and categorized the difficulty of each simulated phishing email using a structured expert review process informed by the NIST Phish Scale framework [22].

Phishing templates were selected from the vendor’s library. We evaluated these templates using the official NIST Phish Scale User Guide methodology to ensure accurate difficulty classification. For the *Phishing Cues* dimension, raters assessed observable indicators that might alert users to fraudulent content, including spelling errors, suspicious URLs, formatting inconsistencies, and sender authenticity markers [14]. For the *Premise Alignment* dimension, raters evaluated how well each email’s subject matter, sender, and content aligned with typical organizational communications that ACME Corp. employees receive in their regular workflow [1].

The assessment team comprised three members of ACME Corp.’s IT security staff, each experienced in identifying real-world phishing attacks. Following Downs *et al.*’s advice, two team members independently evaluated each phishing email template [25]. Any disagreements regarding difficulty classification were discussed and resolved, incorporating a third rater as needed. This collaborative validation process ensured that our phishing simulation represented a controlled range of difficulty levels essential for evaluating training effectiveness across standardized complexity measures [6].

³Control group participants received the same training materials after completion of the study to ensure organizational compliance with cybersecurity awareness requirements. The study timing dictated a small control group, as ACME Corp. required that most employees receive annual cybersecurity training for compliance purposes.

Our final simulation campaign used nineteen phishing templates that we divided into Easy (high cues/low alignment — 5721 emails), Medium (some cues, some alignment — 2279 emails) and Hard (few cues/high alignment — 4511 emails). Table 6 gives a full summary.

Simulation Deployment: Phishing simulations were distributed among participants within a three-month window after training completion. Each participant received one phishing email. Templates were randomly assigned for balanced training conditions.

3.2 Subjects

Study Context: The subjects were full-time employees at a U.S.-based international financial technology (“fintech”) firm. Subjects represented a diverse cross-section of the organization, including employees from finance, technology, operations, customer service, and administrative functions.

Subject Recruitment: This study leveraged organizational security training data collected as part of routine cybersecurity awareness training. The training was introduced in official organizational communications emphasizing its importance for maintaining security compliance and protecting organizational assets. This training was mandatory due to the organization’s regulatory environment.

Data were collected from Dec. 2024 – Apr. 2025. Participants had a one month window to complete their assigned training modules, with automated reminders sent at regular intervals. Training completion was tracked and verified.

Randomization: Subjects were randomly assigned to each treatment. To mitigate bias by organizational role or function, we used stratified sampling [63] across departments to ensure representative distributions in each treatment group.

Completion Rates: Our data came from the 12,511 participants who completed the full experimental protocol. Table 2 shows the completion rates by treatment type. Comparable completion rates across conditions (ranging from 87.3% to 89.1%) suggest our random sample was preserved between recruitment and completion.

3.3 Hypotheses

Based on prior work on phishing training efficacy [16, 17, 30, 33, 36, 62] and documented differences in risk perception [1, 24], we formulated and tested five hypotheses. Table 3 states each hypothesis, its basis, and its relation to prior work. **We hypothesize that:**

Table 2: Recruitment pool and completion rates by condition.

Condition	Recruited	Completed
Treatment A (Lecture)	6,758	6,023 (89.1%)
Treatment B (Lecture + Exercises)	6,764	6,026 (89.1%)
Control Group	529	462 (87.3%)
Total	14,051	12,511 (89.0%)

- (1) **H1 (Phish Scale Effect):** *Phishing emails with higher difficulty, as measured by the NIST Phish Scale, will have higher click-through rates than less difficult ones.*
- (2) **H2 (Training Impact–General):** *Training will increase the detection and reporting of phishing emails.*
- (3) **H3 (Interactive Training Effect–Reporting):** *Interactive components yield higher reporting rates than lecture-only training.*
- (4) **H4 (Interaction Effect):** *There will be an interaction between training modality and phishing difficulty, with interactive training more beneficial for easier lures.*
- (5) **H5 (Reporting Timeliness):** *Training will improve the timeliness of phishing reporting, with trained users reporting suspicious emails more quickly than untrained users.*

With respect to hypothesis novelty and prior testing: **H1** has been tested in small academic settings [6] but never at enterprise scale. **H2** and **H3** build on established training effectiveness research [17, 47, 62] but applies these findings in a large-scale operational context using a standardized difficulty measure; **H4** is novel, addressing the research gap identified by Franz *et al.* [30] regarding interactions between training modality and phishing complexity, which has received minimal empirical attention in prior work. **H5** responds to Steves *et al.*'s question about organizational temporal patterns [61].

3.4 Metrics

Our outcome measures were a mix of standard metrics for comparison to prior results [16, 17, 46] and novel metrics related to response timeliness per Steves *et al.* [61]. We measured using the vendor's simulation platform, which reported the standard metrics directly and gave timing information used to derive our novel metrics.

Standard Metrics: We employed three standard behavioral metrics to assess training effectiveness [16, 17]:

- **Open Rate** is the percent of recipients who *open* the simulated phishing email, measured via embedded tracking pixels.⁴
- **Click-Through Rate (CTR)** is the percent of recipients who *click* on malicious links within the phishing emails. CTR is our primary indicator of phishing susceptibility [62].
- **Reporting Rate** is the percent of recipients who *report* the suspicious email to the organization's security team using the integrated "Report Phish" button, representing proactive security behavior and successful threat recognition [24].

Novel Temporal Metrics: Abroshan *et al.* suggested examining temporal patterns in user responses [1], and Steves *et al.* asked: "Is time to first report sooner than time to first click?" [61]. Rapid reporting of phish attempts enables the feedback loop built into modern

email defenses (Figure 3). We introduce the following metrics to see organizational-level temporal security dynamics:

- **Individual Reporting Timeliness** measures how quickly individual users report suspicious emails:

$$\text{Timeliness}_i = t_{\text{report},i} - t_{\text{deployment}}$$

where $t_{\text{report},i}$ is the timestamp when user i reported the email and $t_{\text{deployment}}$ is when the phishing campaign was launched.

- **Campaign Inoculation Status** determines if an organization can mitigate a phishing campaign before exploitation occurs:

$$\text{Inoculation} = \begin{cases} 1 & \text{if } t_{\text{first report}} < t_{\text{first click}} \\ 0 & \text{otherwise} \end{cases}$$

where $t_{\text{first report}}$ and $t_{\text{first click}}$ are the timestamps of the first report and first click for a given campaign, respectively.

- **Organizational Inoculation Index (OII)** quantifies the temporal advantage (or disadvantage) of reporting over clicking:

$$\text{OII} = t_{\text{first click}} - t_{\text{first report}}$$

Positive values indicate "inoculation" where reports preceded clicks, enabling organizational threat mitigation before exploitation. Negative values instead suggest vulnerability windows.

By directly addressing Steves *et al.* [61], this organizational index evaluates if collective reporting offers a viable early warning window for proactive defense.

3.5 Analysis

Data Validation: After data collection, we validated it to ensure analytical integrity. This included verifying random assignment effectiveness across groups, assessing technical delivery success rates, and examining potential outliers or data anomalies [6].

Statistical Approach: We employed two complementary analytical approaches to examine training effectiveness. Our primary analysis used two-way analysis of variance (ANOVA) to test main effects and interactions between training modality (Treatments A, B, and Control) and phishing difficulty level (Easy, Medium, Hard) on our outcome measures. Note that although ANOVA with binary outcomes violates standard normality assumptions, this approach aligns with established practices in phishing research [16, 17] and enables direct comparison with prior studies.

To address the limitations of ANOVA with binary data, we conducted confirmatory analyses using logistic regression models appropriate for binary outcomes (clicked/not, reported/not) [58]. The logistic regression models employed maximum likelihood estimation and provided odds ratios for effect size interpretation. Both analytical approaches yielded consistent conclusions regarding training effectiveness, with ANOVA providing F-statistics for comparison with prior literature and logistic regression offering more statistically appropriate modeling of our binary outcomes. We report both approaches, while acknowledging the methodological trade-offs inherent in each approach.

3.6 Threats to Validity

We encourage the reader to consider several limitations when interpreting the results of our study [65]. We distinguish these limitations into three kinds of threats to validity.

⁴This is the standard definition, though we acknowledge it can be influenced by email client settings and security configurations [5].

Table 3: Summary of study hypotheses, their theoretical grounding, and relation to prior work. The hypotheses address the effects of phishing email difficulty, training, and training modality on detection and reporting behaviors.

Hypothesis	Theoretical and Empirical Basis	Relation to Prior Work
H1–Phish Scale Effect: <i>Phishing emails with higher difficulty, as measured by the NIST Phish Scale, will have higher click-through rates than less difficult ones.</i>	Grounded in the foundational NIST Phish Scale framework [22] and validation studies [6]. Supported by phishing cue research [14] and systematic email analysis [68].	The NIST Phish Scale has been validated in lab settings [6]. We provide the first large-scale enterprise validation.
H2–Training Impact (General): <i>Training will increase the detection and reporting of phishing emails.</i>	Evidence of training efficacy, reduced click rates [17], improved detection accuracy [62], and short-term benefits [47]. Disputed [36].	Tests whether training effects from small-scale studies [17, 62] replicate at scale, addressing Franz <i>et al.</i> 's call [30].
H3–Interactive Training Effect (Reporting): <i>Interactive components yield higher reporting rates.</i>	Per Franz <i>et al.</i> 's analysis [30], and evidence of effectiveness of active and feedback-rich training [17, 47, 57].	Lab findings show interactive training benefits [17, 47]. We provide the first test at organizational scale.
H4–Interaction Effect: <i>There will be an interaction between training modality and phishing difficulty, with interactive training more beneficial for easier lures.</i>	Emerges from cognitive load and decision strategy research [25], difficulty-aware detection patterns [68], and findings on human limitations [1].	Addresses the gap identified by Franz <i>et al.</i> [30] regarding interaction effects between training and phishing complexity, largely unexplored empirically.
H5–Reporting Timeliness: <i>Trained users will report suspicious emails more quickly than untrained users.</i>	Grounded in studies showing that training enhances threat recognition speed [17]. Supported by evidence that security education improves decision-making efficiency [62].	While individual reporting speed has been measured [42], no studies have examined training effects on organizational-level reporting timeliness [61].

Construct Validity: Construct validity is concerned with whether we operationalized the desired constructs of our study appropriately [59, 67]. In this study, we worked with two primary constructs: (1) the phishing training we deployed, which depends on our cybersecurity training vendor; and (2) our assessment of the difficulty of phishing lures. *First*, though vendors may vary in training design, our cybersecurity vendor's training is regulation-compliant, and our results align with prior work that used different trainings. *Second*, to control for subjectivity in rating phishing lures, we used the NIST Phish Scale with multiple analysts to judge difficulty [60].

Internal Validity: Internal validity threats affect the reliability of conclusions we have about the relationship between the cause and the effect we observe [59, 67]. For our study, we used stratified random sampling to mitigate potential biases related to job role and other organizational issues. Due to the large sample sizes for Treatments A and B, our study has significant statistical power. Organizational constraints required us to limit the sample size for our control group. A priori power analysis indicated that 460 control participants would provide 82% power at $\alpha=0.05$ to detect a 4.5 percentage point difference in click rates between groups. We recruited 529 control group participants, of whom 462 completed the study, exceeding our power requirements and providing an adequate baseline for comparison.

Like all real-world phishing measurement studies, our work faces several measurement concerns. *False positive clicks* may occur when automated security systems (security gateways, antivirus, etc.), “shadow IT” applications, or personally installed tools / browser extensions automatically scan or prefetch URLs from emails, generating click events without actual user interaction. *False negative reporting* may also occur, in which users report phishing emails through alternative channels, such as contacting the IT help-desk

directly, rather than the simulation platform's designated “Report Phish” button. These behaviors would, respectively, incorrectly increase and decrease our measurements of subject interactions. We cannot fully eliminate such threats, but our large sample size mitigates their impact on our overall conclusions.

Although such measurement noise is inherent in operational studies, the large sample size and balanced distribution across conditions mitigate its systematic influence on our results. Every effort was made to standardize user behavior, including explicit instruction during both training modalities on how to identify and report suspicious messages through the organization's approved “Report Phish” mechanism. Future work might explicitly quantify these instrumentation effects by correlating simulation telemetry with downstream SOC logs or ticketing data to better understand their prevalence and direction of bias.

External Validity: External threats impact the generalizability of our research [55, 69]. Our study was situated in the USA at a fintech company. The context of the fintech industry may limit generalizability to other sectors, as financial services employees may have a higher baseline level of security awareness. However, given the minimal effect sizes measured in our study, this threat is not substantial. Our focus on immediate post-training effects also limits our understanding of long-term training impact. Future work might assess the effect of training recency and volume.

3.7 Ethics

Informed consent is critical to empirical studies. Employees are informed at onboarding that periodic phishing simulations are a mandatory condition of employment, consistent with industry

Table 4: Summary of Training Effectiveness Results. Average rates show that trained groups performed similarly to control group, with modest differences across conditions.

Aspect	Results
Effect Size	Consistent with large-scale findings [36]
Training Effect	$\eta^2 = 0.000$ (negligible)
Difficulty Effect	$\eta^2 = 0.007$ (meaningful)
Training $\times$ Difficulty	$\eta^2 = 0.001$ (negligible)
Click Rates	
Overall Click Rate	10.4% across all participants
Control Group Average	9.8%
All Trained Average	10.5%
Training Only	10.6%
Training + Exercise	10.4%
Report Rates	
Overall Report Rate	9.6% across all participants
Control Group Average	8.9%
All Trained Average	9.7%
Training Only	9.5%
Training + Exercise	9.9%
Statistical Effects	
Training Effect on Click Rates	$p = 0.450$ (not significant)
Training Effect on Report Rates	$p = 0.417$ (not significant)
NIST Phish Scale Effect	$p < 0.001$ (highly significant)
Easy Difficulty	7.0% click rate
Medium Difficulty	8.7% click rate
Hard Difficulty	15.0% click rate
Interaction Effects	Revealed nuanced patterns with difficulty levels

practice in financial services organizations [24]. Our study then analyzed data collected as part of routine, required security awareness training, using the existing corporate platform and controls.

Our protocol was reviewed by both the company and the partner academic institution’s IRB. Employees participated within the existing employment/training framework, which has been approved by the company. In consultation with management, we excluded high-distress scenarios (e.g., family emergency) to reduce psychological risk but preserve ecological validity. Because the research used de-identified operational data generated by routine commercial operations, our institutional IRB concluded that from the academic partner’s view our study did not constitute human subjects research.

Regarding the control group, all participants received training (per organizational compliance requirements). After a short, pre-defined delay, the control group received the same training as the treatment groups. This delay enabled the experiment while ensuring all employees received the security training.

4 Results

Our analysis examined the effectiveness of phishing training across 12,511 participants randomly assigned to three experimental conditions. Table 4 gives a summary of our key results. §4 complements this with a depiction of effect sizes for the controlled factors.

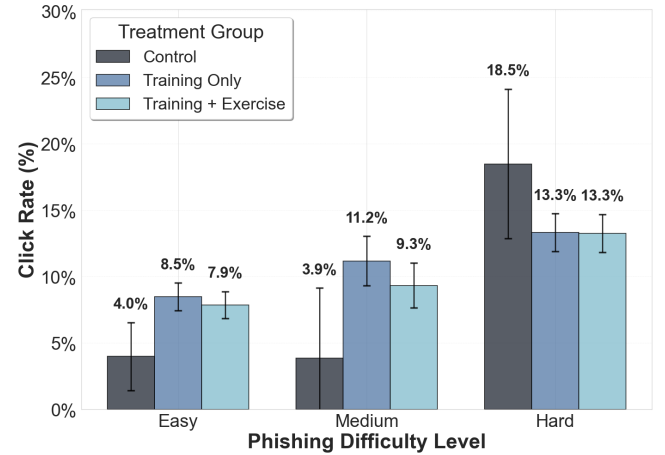


Figure 2: Comparison of effect sizes of phishing susceptibility. Bars show the variance explained by phishing difficulty (per the NIST Phish Scale) for each training intervention.

4.1 H1: Phish Scale Effect

H1 was supported. Figure 2 illustrates the comparison of effect sizes across different factors in phishing susceptibility. The NIST Phish Scale successfully predicted user behavior. Phishing lure difficulty had a highly significant effect on click-through rates ($F(2, 12086) = 41.415$, $p < 0.001$, $\eta^2 = 0.007$), validating the scale’s utility for measuring phishing complexity. Higher difficulty emails consistently produced higher click rates across all experimental conditions; **Easy difficulty**: 7.0% average click rate, **Medium difficulty**: 8.7% average click rate, **Hard difficulty**: 15.0% average click rate.

4.2 H2: Overall Training Effects

H2 was not supported. Training did not produce statistically significant improvements in either click reduction or reporting behavior. Main effect analysis showed no significant difference between trained and untrained groups for click rates ($F(2, 12086) = 0.800$, $p = 0.450$) or report rates ($F(2, 12086) = 0.874$, $p = 0.417$). This finding aligns with recent large-scale evidence suggesting minimal effectiveness of current training approaches [36].

4.3 H3: Interactive Training Effects

H3 was not supported. Treatment B, interactive training (Training + Exercise) did not produce significantly higher reporting rates than traditional training alone. While the interactive group showed numerically higher reporting rates across difficulty levels, these differences were not statistically significant. The coefficient estimate for Training + Exercise relative to Training Only was modest and non-significant across all difficulty levels.

This finding contrasts with some prior work suggesting benefits of interactive training components [17], but aligns with recent large-scale studies showing limited overall training effectiveness [36].

4.4 H4: Training-Difficulty Interactions

H4 was not supported. We found no statistically significant interaction between training modality and lure difficulty for click rates

($F(4, 12086) = 3.135, p=0.014$) or report rates ($F(4, 12086) = 0.517, p=0.723$). While there was a marginal interaction effect for click rates, this primarily reflected the pattern that training appeared to increase clicks on easier emails and reduce clicks on harder emails.

Coefficient analysis revealed some interesting interaction patterns: **Training Only $\times$ Hard**: -9.67 percentage points ($p=0.002$); **Training + Exercise $\times$ Hard**: -9.09 percentage points ($p=0.004$). These significant negative interactions suggest that training may provide some protection against the most difficult phishing emails, even though overall training effects were not significant. Higher alignment messages with fewer cues are the most deceptive [12].

4.5 H5: Reporting Timeliness

H5 was partially supported, though with important caveats about sample size limitations. Individual reporting behavior showed a median time-to-report of 21 minutes (0.35 hours), with 90% of reports occurring within 18.8 hours of phishing deployment. We analyzed 17 templates that received both clicks and reports. Overall, 52.9% achieved inoculation (reports preceded clicks), with median Organizational Inoculation Index (OII) of +0.4 hours. By treatment group, Control achieved inoculation on 66.7% of templates (median OII: +0.3 hours), Training Only on 75% (median OII: +1.37 hours), and Training + Exercise on only 28.6% (median OII: -0.2 hours). These differences were not statistically significant due to limited sample size. For successfully inoculated templates, the median OII was approximately 30 minutes, suggesting automated response mechanisms would be necessary to mitigate threats before exploitation.

These findings provide the first empirical measurement of organizational temporal security dynamics, responding to Steves *et al.*'s research question about whether "time to first report is sooner than time to first click" [61]. The results suggest that organizational-level protective behaviors operate independently of individual training effectiveness. This feedback loop is a direction for further study.

4.6 Effect Sizes and Practical Significance

While some coefficients reached statistical significance, effect sizes were generally small ($\eta^2 < 0.01$), raising questions about practical significance [62]. The only meaningful effect was the difficulty gradient ($\eta^2 = 0.007$ for click rates), confirming the NIST Phish Scale's predictive validity. Even statistically significant interaction effects represented changes of less than 10 percentage points.

These findings underscore the need for realistic expectations about training effectiveness and suggest organizations should complement training with other defense mechanisms rather than relying on awareness programs as primary protection [30].

5 Discussion

5.1 Implications for Practice

After deploying regulation-compliant training programs to over 12,000 employees, we found no statistically significant main effects of training on either click rates ($p=0.450$) or report rates ($p=0.417$). The small effect sizes we observed ($\eta^2 < 0.01$ for all main effects) indicate that even statistically significant improvements translate to minimal operational impact. This result aligns with recent large-scale evidence from Ho *et al.* [36] and challenges the optimistic assessments promoted by cybersecurity training vendors.

The predictive power of the NIST Phish Scale ($F(2, 12086)=41.415, p < 0.001$) demonstrates that practitioners can significantly influence training results by adjusting the difficulty of phishing lures used in simulations. Our data shows click rates vary dramatically based on lure difficulty: from 7.0% for easy emails to 15.0% for hard emails. Organizations setting specific performance targets (such as click-through rates around 2%) may achieve these by using low-difficulty lures that fail to represent sophisticated attacks organizations actually face [3]. This creates a misalignment between perceived and actual security posture.

These findings suggest several actionable opportunities for both training vendors and organizational security teams. Vendors can enhance their value by incorporating standardized measures of lure difficulty and adaptive testing frameworks aligned with models such as the NIST Phish Scale. This would produce interpretable results that organizations could use to calibrate difficulty levels to track progress over time, personalize training to employee risk profiles, and benchmark outcomes across departments or industries. However, the relatively low impact of phishing training suggests that awareness programs must be part of a layered defense strategy, complemented by technical controls and incident response preparedness [30], to gain risk reduction rather than nominal compliance [33]. In this way, security awareness initiatives can evolve from static, one-size-fits-all modules into data-driven, context-aware components of an organization's continuous improvement process.

5.2 Future Work

Refinement of Organizational Inoculation Index: Our introduction of the Organizational Inoculation Index offers a starting point for measuring collective security behaviors across a workforce. We suggest that this metric might be a useful addition to large-scale phishing simulation tools, as it provides a valuable assessment of how quickly and effectively an organization responds to bulk phishing threats at scale, although its utility against spear phishing (especially in the age of LLMs) is unclear.

AI-Generated Phishing and the Limits of the NIST Phish Scale: The emergence of generative AI enables highly convincing phishing attacks at scale that lack traditional flaws used to assess difficulty, such as unsecured websites [37] or poor grammar [54]. This calls into question the continued relevance of the NIST Phish Scale. Future research should investigate whether training methods can prepare users to recognize AI-crafted phishing attempts.

6 Conclusion

This work provides the largest validation to date of the NIST Phish Scale through its application across multiple experimental conditions. Difficulty strongly predicted user behavior (click rates from 7.0% for easy lures to 15.0% for hard; $F(2, 12086) = 41.415, p < 0.001$), while neither interactive nor lecture-based training produced statistically significant changes in click rates ($p=0.450$) or reporting behavior ($p=0.417$). These results confirm prior work while running counter to industry marketing claims. Our evidence indicates that training provides only modest protection against phishing threats and should be regarded as just one component of a broader security awareness program. This reproduction evaluates new hypotheses and contexts.

References

- [1] Hossein Abroshan, Jan Devos, Geert Poels, and Eric Laermans. Phishing Happens Beyond Technology: The Effects of Human Behaviors and Demographics on Each Step of a Phishing Process. *IEEE access : practical innovations, open solutions*, 9:44928–44949, 2021.
- [2] Ahmed Aleroud and Lu Zhou. Phishing environments, techniques, and counter-measures: A survey. *Computers & Security*, 68:160–196, 2017.
- [3] Zainab Alkhalil, Chaminda Hewage, Liqaa Nawaf, and Intiaz Khan. Phishing Attacks: A Recent Comprehensive Study and a New Anatomy. *Frontiers in Computer Science*, 3:563060, March 2021.
- [4] K. Andersen, B. Long, S. Blank, and M. Kucherawy. The authenticated received chain (ARC) protocol. Technical Report RFC 8617, IETF, 2019.
- [5] D. Antoniou. A systematic method to execute simulated phishing tests. Master's thesis, Technical University of Delft, Delft, Netherlands, 2015.
- [6] Fern Barrientos, Jody Jacobs, and Shaneé Dawkins. Scaling the Phish: Advancing the NIST Phish Scale. In Constantine Stephanidis, Margherita Antona, and Stavroula Ntoa, editors, *HCI International 2021 - Posters*, volume 1420, pages 383–390. Springer International Publishing, Cham, 2021. Series Title: Communications in Computer and Information Science.
- [7] BIMi Group / AuthIndicators. Brand indicators for message identification (BIMI) – overview, 2025.
- [8] Paula Bitrián, Isabel Buil, Sara Catalán, and Dominik Merli. Gamification in workforce training: Improving employees' self-efficacy and information security and data protection behaviours. *Journal of Business Research*, 179:114685, June 2024.
- [9] A. Brotman and others. General guidance for implementing branded indicators for message identification (BIMI), 2025. tex.howpublished: IETF Internet-Draft.
- [10] Lina Brunken, Annalina Buckmann, Jonas Hielscher, and M. Angela Sasse. "To Do This Properly, You Need More Resources": The Hidden Costs of Introducing Simulated Phishing Campaigns. In *USENIX Security Symposium*, 2023.
- [11] AJ Burns, M Eric Johnson, and Deanna D Caputo. Spear phishing in a barrel: Insights from a targeted phishing campaign. *Journal of Organizational Computing and Electronic Commerce*, 29(1):24–39, 2019.
- [12] Marcus Butavicius, Kathryn Parsons, Malcolm Pattinson, and Agata McCormac. Breaching the human firewall: Social engineering in phishing and spear-phishing emails. In *Proceedings of the Australasian Conference on Information Systems (ACIS 2015)*, 2015.
- [13] Casey Inez Canfield, Baruch Fischhoff, and Alex Davis. Better beware: comparing metacognition for phishing and legitimate emails. *Metacognition and Learning*, 14(3):343–362, December 2019.
- [14] Matthew Canham, Shaneé Dawkins, and Jody Jacobs. Not All Victims Are Created Equal: Investigating Differential Phishing Susceptibility. In Dylan D. Schmorow and Cali M. Fidopiastis, editors, *Augmented Cognition*, volume 14694, pages 3–21. Springer Nature Switzerland, Cham, 2024. Series Title: Lecture Notes in Computer Science.
- [15] Matthew Canham, Clay Posey, and Michael Constantino. Phish Derby: Shoring the Human Shield Through Gamified Phishing Attacks. *Frontiers in Education*, 6:807277, January 2022.
- [16] Deanna D. Caputo, Shari Lawrence Pleegeer, Jesse D. Freeman, and M. Eric Johnson. Going Spear Phishing: Exploring Embedded Training and Awareness. *IEEE Security & Privacy*, 12(1):28–38, January 2014.
- [17] Angelo Carella, Maxim Kotsoev, and Tudor M Truta. Impact of security awareness training on phishing click-through rates. In *2017 IEEE international conference on Big Data (Big Data)*, pages 4458–4466. IEEE, 2017.
- [18] Euijin Choo, Mohamed Nabeel, Doowon Kim, Ravindu De Silva, Ting Yu, and Issa Khalil. A large scale study and classification of virustotal reports on phishing and malware urls. In *Abstracts of the 2024 ACM SIGMETRICS/IFIP PERFORMANCE Joint International Conference on Measurement and Modeling of Computer Systems*, SIGMETRICS/PERFORMANCE '24, page 55–56, New York, NY, USA, 2024. Association for Computing Machinery.
- [19] D. Crocker, T. Hansen, and M. Kucherawy. DomainKeys identified mail (DKIM) signatures. Technical Report RFC 6376, IETF, 2011.
- [20] Cybersecurity and Infrastructure Security Agency. Scattered spider: Threat group analysis, 2023.
- [21] Avisha Das, Shahryar Baki, Ayman El Aassal, Rakesh Verma, and Arthur Dunbar. SoK: A Comprehensive Reexamination of Phishing Research From the Security Perspective. *IEEE Communications Surveys & Tutorials*, 22(1):671–708, 2020.
- [22] Shaneé Dawkins and Jody Jacobs. NIST Phish Scale user guide. Technical Report NIST TN 2276, National Institute of Standards and Technology (U.S.), Gaithersburg, MD, November 2023.
- [23] Giuseppe Desolda, Lauren S. Ferro, Andrea Marrella, Tiziana Catarci, and Maria Francesca Costabile. Human Factors in Phishing Attacks: A Systematic Literature Review. *ACM Computing Surveys*, 54(8):1–35, November 2022.
- [24] Anne-Kee Doing, Eduardo Bárbaro, Frank Van Der Roest, Pieter Van Gelder, Yury Zhauniarovich, and Simon Parkin. An analysis of phishing reporting activity in a bank. In *Proceedings of the 2024 European Symposium on Usable Security*, pages 44–57, Karlstad Sweden, September 2024. ACM.
- [25] Julie S. Downs, Mandy B. Holbrook, and Lorrie Faith Cranor. Decision strategies and susceptibility to phishing. In *Proceedings of the second symposium on Usable privacy and security - SOUPS '06*, page 79, Pittsburgh, Pennsylvania, 2006. ACM Press.
- [26] European Parliament and Council. GDPR Article 39: Tasks of the data protection officer, 2016.
- [27] Ana Ferreira and Soraia Teles. Persuasion: How phishing emails can influence users and bypass security measures. *International Journal of Human-Computer Studies*, 125:19–31, May 2019.
- [28] International Organization for Standardization (ISO). ISO/IEC 27001:2022 - information security, cybersecurity and privacy protection, 2022.
- [29] Matthew Franklin, Jason R. C. Nurse, and Duncan Hodges. Optimising nudges and boosts for cybersecurity behaviour, 2019.
- [30] Anjuli Franz, Verena Zimmermann, Gregor Albrecht, Katrin Hartwig, Christian Reuter, Alexander Benlian, and Joachim Vogt. SoK: Still plenty of phish in the sea – a taxonomy of User-Oriented phishing interventions and avenues for future research. In *Seventeenth Symposium on Usable Privacy and Security (SOUPS 2021)*, pages 339–358. USENIX Association, August 2021.
- [31] Frank L. Greitzer, Wanru Li, Kathryn B. Laskey, James Lee, and Justin Purl. Experimental Investigation of Technical and Human Factors Related to Phishing Susceptibility. *ACM Transactions on Social Computing*, 4(2):1–48, June 2021.
- [32] Group-IB Threat Intelligence. Oktapus: Multi-phishing Threat Actors Use Phishing-as-a-Service and Smishing Triad, 2022.
- [33] Julie Haney and Wayne Lutters. From compliance to impact: Tracing the transformation of an organisational security awareness programme. *Cyber Security: A Peer-Reviewed Journal*, 8(2):110–130, 2025.
- [34] Stephen Hart, Andrea Margheri, Federica Paci, and Vladimiro Sassone. Riskio: A Serious Game for Cyber Security Awareness and Education. *Computers & Security*, 95:101827, August 2020.
- [35] Doron Hillman, Yaniv Harel, and Eran Toch. Evaluating organizational phishing awareness training on an enterprise scale. *Computers & Security*, 132:103364, September 2023.
- [36] Grant Ho, Ariana Mirian, Elisa Luo, Khang Tong, Euyhyun Lee, Lin Liu, Christopher A Longhurst, Christian Dameff, Stefan Savage, and Geoffrey M Voelker. Understanding the Efficacy of Phishing Training in Practice. *IEEE Symposium on Security and Privacy*, 2025.
- [37] Doowon Kim, Haehyun Cho, Yonghwi Kwon, Adam Doupé, Soeul Son, Gail-Joon Ahn, and Tudor Dumitras. Security analysis on practices of certificate authorities in the https phishing ecosystem. In *Proceedings of the 2021 ACM Asia Conference on Computer and Communications Security*, ASIA CCS '21, page 407–420, New York, NY, USA, 2021. Association for Computing Machinery.
- [38] Iacovos Kirlappos and M. Angela Sasse. Security Education against Phishing: A Modest Proposal for a Major Rethink. 10(2):24–32.
- [39] Scott Kitterman. Sender policy framework (SPF) for authorizing use of domains in email, version 1. Technical Report RFC 7208, IETF, 2014.
- [40] M. Kucherawy and E. Zwicky. Domain-based message authentication, reporting, and conformance (DMARC). Technical Report RFC 7489, IETF, 2015.
- [41] Daniele Lain, Fabio Ceschin, Giancarlo Pellegrino, and Lorenzo Cavallaro. Content, nudges and incentives: A study on the effectiveness and perception of embedded phishing training. In *Proceedings of the 2024 ACM SIGSAC conference on computer and communications security*, pages 4182 – 4196, 2024.
- [42] Daniele Lain, Kari Kostiaainen, and Srdjan Capkun. Phishing in Organizations: Findings from a Large-Scale and Long-Term Study, December 2021. arXiv:2112.07498 [cs].
- [43] Kiho Lee, Kyungchan Lim, Hyoungshick Kim, Yonghwi Kwon, and Doowon Kim. 7 days later: Analyzing phishing-site lifespan after detected. In *Proceedings of the ACM on Web Conference 2025*, WWW '25, page 945–956, New York, NY, USA, 2025. Association for Computing Machinery.
- [44] Kyungchan Lim, Kiho Lee, Fujiao Ji, Yonghwi Kwon, Hyoungshick Kim, and Doowon Kim. What's in phishers: A longitudinal study of security configurations in phishing websites and kits. In *Proceedings of the ACM on Web Conference 2025*, WWW '25, page 957–968, New York, NY, USA, 2025. Association for Computing Machinery.
- [45] Kyungchan Lim, Jaehwan Park, and Doowon Kim. Phishing vs. legit: Comparative analysis of client-side resources of phishing and target brand websites. In *Proceedings of the ACM Web Conference 2024*, WWW '24, page 1756–1767, New York, NY, USA, 2024. Association for Computing Machinery.
- [46] Pablo López-Aguilar, Carlota Urruela, Edgar Batista, Juvenal Machin, and Agustí Solanas. Phishing vulnerability and personality traits: Insights from a systematic review. *Computers in Human Behavior Reports*, 20:100784, 2025. <https://www.sciencedirect.com/science/article/pii/S245195882500199X>.
- [47] Nina Marshall, Daniel Sturman, and Jaime C. Auton. Exploring the evidence for email phishing training: A scoping review. *Computers & Security*, 139:103695, April 2024.
- [48] Uta Menges and Annette Kluge. Contrasting and Synergizing CISOs' and Employees' Attitudes, Needs, and Resources for Security Using Personas. In *2024 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)*, pages 456–472, Vienna, Austria, July 2024. IEEE.
- [49] Microsoft. Safe links in microsoft defender for office 365.

- [50] National Institute of Standards and Technology. NIST Cybersecurity Framework 2.0, 2024.
- [51] PCI Security Standards Council. Payment Card Industry Data Security Standard (PCI DSS), 2024.
- [52] Andrew Reeves, Dragana Calic, and Paul Delfabbro. “get a red-hot poker and open up my eyes, it’s so boring” 1: Employee perceptions of cybersecurity training. *Computers & security*, 106:102281, 2021.
- [53] Reuters. MGM Resorts Estimates \$100 Million Loss from Cyber Attack, 2024.
- [54] Sayak Saha Roy, Poojitha Thota, Krishna Vamsi Naragam, and Shirin Nilizadeh. From Chatbots to Phishbots?: Phishing scam generation in commercial Large Language Models. In *2024 IEEE symposium on security and privacy (SP)*, pages 36–54, San Francisco, CA, USA, 2024. IEEE.
- [55] Per Runeson and Martin Höst. Guidelines for conducting and reporting case study research in software engineering. *Empirical Software Engineering*, 14(2):131–164, 2009.
- [56] M. A. Sasse, S. Brostoff, and D. Weirich. Transforming the ‘Weakest Link’ - a Human-Computer Interaction Approach to Usable and Effective security. In Robert Temple and John Regnault, editors, *Internet and Wireless Security*, pages 243–262. Institution of Engineering and Technology.
- [57] Lorin Schöni, Victor Carles, Martin Strohmeier, Peter Mayer, and Verena Zimmermann. You Know What? - Evaluation of a Personalised Phishing Training Based on Users’ Phishing Knowledge and Detection Skills. In *Proceedings of the 2024 European Symposium on Usable Security*, pages 1–14, Karlstad Sweden, September 2024. ACM.
- [58] Skipper Seabold and Josef Perktold. statsmodels: Econometric and statistical modeling with python. In *9th python in science conference*, pages 92–96. SciPy, 2010.
- [59] William R. Shadish, Thomas D. Cook, and Donald T. Campbell. *Experimental and quasi-experimental designs for generalized causal inference*. Houghton Mifflin, Boston, MA, USA, 2002.
- [60] Dag I. K. Sjøberg and Gunnar R. Bergersen. Construct validity in software engineering. *IEEE Transactions on Software Engineering*, 49(3):1374–1396, 2023.
- [61] Michelle Steves, Kristen Greene, and Mary Theofanos. Categorizing human phishing difficulty: a Phish Scale. *Journal of Cybersecurity*, 6(1):tyaa009, January 2020.
- [62] Alex Sumner, Xiaohong Yuan, Mohd Anwar, and Maranda McBride. Examining Factors Impacting the Effectiveness of Anti-Phishing Trainings. *Journal of Computer Information Systems*, 62(5):975–997, September 2022. <https://www.tandfonline.com/doi/full/10.1080/08874417.2021.1955638>.
- [63] Thomas Sutter, Ahmet Selman Bozkir, Benjamin Gehring, and Peter Berlich. Avoiding the Hook: Influential Factors of Phishing Awareness Training on Click-Rates and a Data-Driven Approach to Predict Email Difficulty Perception. *IEEE Access*, 10:100540–100565, 2022.
- [64] U.S. Department of Health and Human Services. HIPAA Security Rule, 2003.
- [65] Roberto Verdecchia, Emelie Engström, Patricia Lago, Per Runeson, and Qunying Song. Threats to validity in software engineering research: A critical reflection. *Information and Software Technology*, 164:107329, 2023. <https://www.sciencedirect.com/science/article/pii/S0950584923001842>.
- [66] Melanie Volkamer, Verena Zimmermann, Benjamin Fabian, Nina Gerber, and Sebastian Feld. Making it (even) harder: On the difficulty of phishing attacks in view of security indicators. In *International conference on human-computer interaction*, pages 319–338. Springer, 2020.
- [67] Claes Wohlin, Per Runeson, Martin Höst, Magnus C. Ohlsson, Björn Regnell, and Anders Wesslén. *Experimentation in software engineering*. Springer, Berlin, Heidelberg, 2012.
- [68] Ryan Wright, Steven Johnson, and Brent Kitchens. Phishing Susceptibility in Context: A Multilevel Information Processing Perspective on Deception Detection. *MIS Quarterly*, 47(2):251–270, 2023.
- [69] Robert K. Yin. *Case Study Research: Design and Methods*. SAGE Publications, 6th edition, 2018.

Acknowledgments

The authors are grateful to Kimberly Hung for contributions to the visual design of the paper and figures, to Ali Varshovi for the discussion that motivated our analysis of the organizational inoculation metrics, and to Katie Daniels for short-notice odd-hour assistance with statistical analysis.

Appendices

The extended material presented here consists of:

- Appendix A: The studied organization’s email flow

- Appendix B: Definition of the NIST Phish Scale
- Appendix C: Details of the lures used

A Email Controls in the Studied Organization

Figure 3 depicts the studied organization’s email processing flow, with defenses noted and our metrics placed in the broader context.

The following is a detailed sequence of the controls in the studied organization’s email defense setup. The studied organization uses services from Microsoft (e.g., Safe Attachments, Zero-Hour Auto Purge), other vendors, and industry-standard protocols (e.g., SPF, DKIM, DMARC, MTA-STS).

Malicious Email Sent An attacker crafts a convincing message and sends it from a look-alike or compromised account, often using links or attachments that lead to theft or malware.

Email Authentication: SPF The domain owner lists which mail servers are allowed to send on its behalf; receivers check the sender’s IP against that list to spot forgeries.

Email Authentication: DKIM The sender adds a digital signature to the message; receivers use a public key in DNS to confirm the message really came from that domain and wasn’t altered.

Email Authentication: DMARC Builds on SPF/DKIM to tell receivers what to do with failures (monitor, quarantine, or reject) and sends reports back to the domain owner.

Email Authentication: BIMi A visual cue: providers that support it can display a verified brand logo when strong DMARC is in place; it helps users spot impostors.

Email Authentication: ARC Preserves original authentication results across forwarding/mailling lists so legitimate forwarded mail isn’t penalized.

Transport Encryption: STARTTLS Upgrades the SMTP connection to TLS so email isn’t readable in transit between servers.

Transport Enforcement: MTA-STS Lets a domain publish a policy that its email must use TLS with valid certificates—blocking downgrade/MITM attempts.

Transport Enforcement: DANE Uses DNSSEC to bind TLS certificates to the domain for SMTP, strengthening spoofing/interception resistance.

Secure Email Gateway (SEG) The organization’s front door for mail: filters spam/phishing, checks sender/domain reputation, analyzes headers/content, and often rewrites links for time-of-click checks.

Threat Intelligence Integration & Update Feeds of known-bad IPs, domains, URLs, and file hashes; standards like STIX/TAXII and programs like CISA AIS enable sharing and automation.

AI/ML Threat Detection Behavioral and language models look for impersonation and anomalies beyond fixed indicators—useful for brand-new or targeted lures.

Attachment Sandboxing Opens attachments in an isolated virtual environment (“detonation”) to observe malicious behavior and block delivery.

Content Disarm & Reconstruction (CDR) Strips active content (macros, scripts) from files and rebuilds a safe version so users can still open the content.

Data Loss Prevention (Outbound Scanning) Watches outgoing mail for sensitive data (e.g., customer lists, PHI); can also flag compromised accounts trying to exfiltrate information.

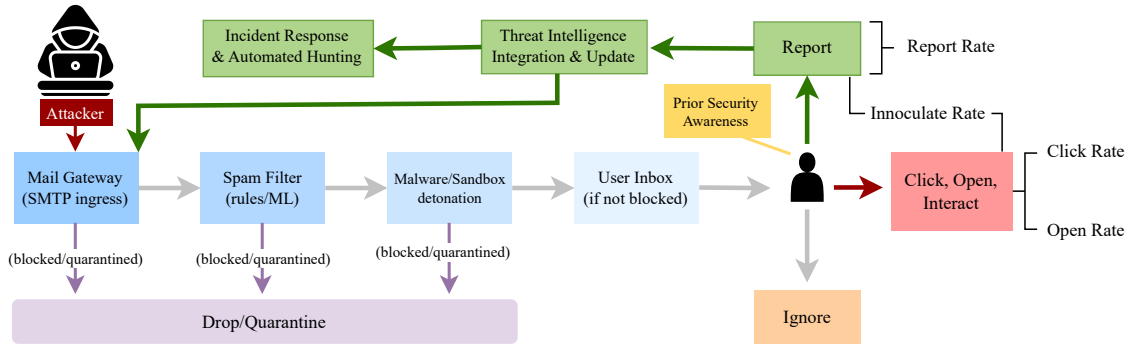


Figure 3: Phishing defense architecture, mapping the email pathway from authentication through post-delivery response. Technical controls create multiple interception points prior to human interaction, and human reports provide a feedback opportunity for organizational-level threat mitigation.

Delivered to User Inbox Messages that pass earlier controls arrive for the user—this is where human judgment and endpoint protections matter.

Email Client Security Clients/services block auto-loading images, scan/contain attachments, and add safety banners to reduce risk on open/click.

Security Awareness Training & Simulation Short, regular training and realistic simulations teach users what to look for and build a habit of reporting.

User Reports Phish One-click “Report Phish” sends the message to security; reported samples help purge look-alikes and improve filters.

SIEM/SOAR Integration Centralizes mail/endpoint alerts and runs automated playbooks to block senders, remove messages, and open tickets.

Incident Response & Automated Hunting Analysts confirm threats, retro-hunt for variants, remove messages, and contain affected accounts/devices.

Zero-Hour Auto Purge (ZAP) If a campaign is discovered post-delivery, the system can retroactively remove those emails from mailboxes.

Email Quarantine Management Suspicious but unconfirmed messages are held for review so security teams (or users, with guardrails) can release or delete.

Mobile Device Management (MDM) Enforces secure mail apps, screen locks, and remote wipe on phones/tablets that access corporate email.

Email Retention & Backup Systems Archiving/backups keep searchable records for investigations/compliance and permit restoration after an incident.

B Measuring Lure Complexity with the NIST Phish Scale

As discussed in §2.2, we used the NIST Phish Scale as a standardized measure of phishing lure difficulty, *i.e.*, the relative difficulty of detecting whether or not a given email is part of a phishing attack. The NIST Phish Scale is intended to help organizations benchmark lure complexity and contextualize simulation outcomes [15]. It

categorizes lure difficulty along two dimensions, shown in Table 5. Barrientos *et al.* [6] conducted early validation work on the NIST Phish Scale, while Dawkins and Jacobs [22] provided the official implementation guidelines. Ours is the first study to validate the Phish Scale’s premise at scale in a real-world context.

Table 5: NIST Phish Scale for Detection Difficulty [22, 61]. *Phishing Cues* represent observable errors or inconsistencies in the email that might alert users to its fraudulent nature, *e.g.*, suspicious URLs or formatting irregularities [14]. *Premise Alignment* measures the relevance of the email to the recipient’s organizational context [5].

Cues \ Alignment	Weak	Medium	Strong
Few	Medium	Hard	Hard
Some	Easy-to-Medium	Medium	Hard
Many	Easy	Medium	Medium

C Lures

See Table 6 for our analysis of the phishing lures used in this study.

Following the NIST Phish Scale framework, we created a 3×3 classification matrix combining cue visibility (few-low, some-medium, many-high) with premise alignment (weak-low, medium, strong-high). Templates were assigned composite difficulty scores by summing both dimensions, with scores ranging from 2 (easy: high cues, low alignment) to 6 (hard: low cues, high alignment). Based on lure and premise scores, we mapped the top group to “Easy”, the middle group to “Medium”, and the bottom group to “Hard”.

The deployed templates were constrained by organizational considerations. ACME Corp.’s management requested the exclusion of highly distressing content (*e.g.*, emergency family situations, personnel security scenarios) to minimize employee psychological impact. This constraint reflects the practical limitations of conducting research within operational environments, where employee welfare considerations influence experimental designs [24].

Table 6: NIST Phish Scale Assessment of Phishing Templates Used In This Study. Premise Alignment scores range from 1 (Low) to 3 (High). Lure Scores range from 1-3 based on phishing cue assessment. Cue Count represents the total number of suspicious indicators identified in each template. Based on lure and premise scores, we mapped the top group to “Easy”, the middle group to “Medium”, and the bottom group to “Hard”.

Template Name	Difficulty	Cue Count	Lure Score	Premise Score	Premise Alignment Explanation
Attachment - XLS	Easy	14	2	2	Moderate alignment: XLS financial data plausible, but lacks sender/context.
Fax via Voicemail Office	Easy	13	2	1	Low alignment: Fax delivery uncommon in modern workplace.
Email Not Delivered Office	Easy	13	2	3	High alignment: Bounce messages routine and widely expected.
Email Not Delivered Google	Easy	16	3	3	High alignment: Gmail bounce notices with technical detail believable.
From Marketing: Collab Request	Easy	14	2	3	High alignment: Internal collaboration messages from marketing common.
Accounting Team Amex Charges Office	Easy	16	3	3	High alignment: Finance inquiries during month-end familiar.
HSA Use Balance!	Easy	17	3	2	Moderate alignment: HSA reminders expected, but lacks personalization.
Tax Workshop	Easy	16	3	2	Moderate alignment: HR tax webinars plausible but weakened by generic formatting.
Device Non-compliant - Microsoft	Medium	15	3	3	High alignment: Matches expected MDM behavior and terminology.
Mobile Device Restricted Outlook	Medium	16	3	3	High alignment: Device quarantine messages match common security flows.
Device Non-compliant - Google	Medium	16	3	3	High alignment: Technical restriction notices align with enterprise environments.
Attachment - Word	Hard	14	2	2	Moderate alignment: Document sharing plausible, but placeholder fields reduce realism.
Vulnerabilities Office	Hard	18	3	1	Low alignment: Scenario vague and not role-specific; unlikely context.
Loom - Recording Shared	Hard	14	2	2	Moderate alignment: Loom recordings common, but template fields weaken trust.
Mentor Program	Hard	15	3	3	High alignment: Internal mentorship invitations believable and well-framed.
HR - Performance Review Outlook	Hard	16	3	3	High alignment: Outlook calendar invites for reviews routine.
Changes to Healthcare Form	Hard	15	3	3	High alignment: Healthcare form updates common in HR communications.
Vulnerabilities Google	Hard	16	3	1	Low alignment: Scenario lacks specificity and role-relevant context.